

Universidad de Valladolid

SGSI Empresa Medisalud Integral S.A.

15 de diciembre de 2025

Garantía y Seguridad de la Información

3º Curso – Tecnologías de la Información

Grupo P2-3

Integrantes:

Luis Antón

Alfredo del Val

Daniel Sanabria

Roi Suárez

Índice

1. Características de la empresa 3
1.1 Panorámica IT de la empresa 3
1.2 Departamento y ubicaciones 3
1.3 Infraestructura IT 4
1.4 Servicios necesarios en la organización 5
1.5 Requerimientos de acceso interno y externo 6
1.6 Política de seguridad 7
1.7 Agentes implicados 7
2. Análisis de riesgos 8
2.1 Catálogo de activos 8
2.2 Listado de amenazas 12
2.3 Listado de riesgos 14
2.4 Priorización de riesgos 17
3. Salvaguardas (Contramedidas de seguridad) 18
3.1 Por objetivo de seguridad 18
3.2 Por tipo de activo 20
4. Controles del SGSI 20
4.1 Controles organizacionales 20
4.2 Controles técnicos 21
4.3 Controles físicos 21
4.4 Controles de comunicación 22
4.5 Controles legales 22
5. Bibliografía 22
6. Anexo 22

1. Características de la empresa

1.1 Panorámica IT de la empresa

Medisalud Integral S.A. es una cadena de clínicas privadas fundada en el año 2005 por un grupo de médicos emprendedores que buscaban ofrecer servicios sanitarios de calidad en ciudades de tamaño medio, con un enfoque cercano y accesible para los pacientes. Esta empresa presenta una dependencia a las tecnologías de la información ya que ahí almacenan: historiales clínicos electrónicos, gestión de citas online, tele-consulta, facturación electrónica y complementos de normativas. Para Medisalud Integral S.A. la disponibilidad y seguridad de sus sistemas informáticos son esenciales para garantizar la continuidad de su negocio y la confianza de sus pacientes.

1.2 Departamento y ubicaciones

La estructura organizativa de la organización se compone de los siguientes departamentos:

- **Dirección General:** formada por el director general, el director médico y el responsable financiero. La función principal de este departamento es la coordinación estratégica y supervisión global de la empresa.
- **Departamento Médico:** formado por médicos y personal de enfermería. La función principal de este departamento es la prestación de servicios asistenciales y gestión clínica.
- **Departamento de Administración y Finanzas:** formado por el personal administrativo. La función principal de este departamento es la gestión económica, contable y administrativa.
- **Departamento de Atención al Paciente:** formado por el personal de recepción. La función principal de este departamento es la relación directa con los pacientes y/o familiares de los mismos.
- **Departamento de TI y Seguridad:** formado por el administrador de sistemas y soporte. La funcionalidad principal de este departamento es la administración de sistemas, dotándolas de soporte técnico y ciberseguridad.
- **Servicios externalizados adicionales:** formados por un número indefinido y variable de personal de limpieza, mantenimiento y especialistas en equipos médicos.

1.3 Infraestructura IT

Se trata del conjunto de elementos tanto físicos como lógicos que la empresa utiliza para la gestión, procesamiento, almacenamiento y transmisión de la información. En Medisalud Integral S.A, este es el listado de recursos de TI que se usarán:

- **Componentes Hardware**:
    - Portátiles de la marca Dell Latitude
    - Servidores Dell PowerEdge
    - Routers Cisco RV340.
- **Componentes Software**:
    - Cada portátil viene con el sistema operativo Windows 11 instalado
    - Los servidores tendrán instalado la plataforma de virtualización VMware vSphere
    - Para cada máquina virtual de esa plataforma de virtualización, se usará los siguientes software de ámbito sanitario y empresarial:
        - OpenEMR: Software de administración de práctica médica
        - OsiriX PACS: Para leer y mostrar todo tipo de archivos DICOM generados mediante técnicas de imagen médica
        - A3 ERP: Software de ámbito empresarial que unifica la gestión de diferentes áreas como contabilidad, facturación, almacén y nóminas en una única plataforma
        - SQL Server: Base de datos
    - En caso de fallos o errores, existen backups creados con la utilidad Veeam que funciona para la plataforma de VMware y utiliza el servicio de Microsoft Azure para almacenarlo en la nube.
    - Los servicios de red empleados por la empresa son AWS (IaaS, PaaS, SaaS), Microsoft Azure (IaaS, PaaS, SaaS), Google Workspace (SaaS) y Salesforce Health Cloud (SaaS).
    - En cuanto a la conectividad entre todos los elementos de la red está presente las tecnologías LAN, el uso de VPN site-to-site IPSec, la seguridad con los firewalls Fortinet FortiGate 60F y la presencia de
    - Por último, en cuanto la protección frente amenazas, se cuenta con Snorti como software IDS/IPS para la detección y prevención de intrusiones, el antivirus Trend Micro Apex One y el uso de autenticación multifactor (MFA) con Duo Security.

1.4 Servicios necesarios en la organización

La operación de Medisalud Integral S.A. depende críticamente de sus sistemas de información.

- **Servicios asistenciales críticos:** Estos son esenciales para la atención al paciente y el cumplimiento normativo.
    - **Historia Clínica Electrónica (HCE):** Gestión del historial de pacientes, incluyendo consultas y tratamientos (uso de **OpenEMR**).
    - **Sistema de Archivo y Comunicación de Imágenes (PACS):** Visualización y gestión de imágenes radiológicas (uso de **OsiriX MD**).
    - **Gestión de Laboratorio (LIMS):** Introducción de resultados de análisis de sangre (**Lab Ware LIMS**).
    - **Tele-consulta:** Permite la atención remota.

- **Servicios de Gestión Empresarial y Administrativa:**
    - **Planificación de Recursos Empresariales (ERP):** Gestión integral de la empresa, incluyendo aspectos sanitarios (**SAP Business One**) y contable/nóminas (**A3 ERP**).
    - **Gestión de Relaciones con el Cliente (CRM):** Para la gestión de citas, recordatorios por SMS/email y registro de interacciones (**Salesforce Health Cloud**).
    - **Call Center y VoIP:** Para la atención telefónica a pacientes y familiares (**Genesys Cloud CX**).
    - **Facturación Electrónica:** Generación y envío de facturas (**Facturae**).
    - **Portal de Citas Online:** Servicios en la nube para la gestión de citas (**WordPress + WooCommerce** en **AWS**).
    - **Inteligencia de Negocio (BI):** Para la revisión de indicadores de negocio (**Power BI**).
    - **Correo y Colaboración:** Servicios de oficina y comunicación (**Google Workspace**).

- **Servicios de infraestructura y Seguridad de TI:**
    - **Gestión de Identidades:** Creación y control de cuentas de usuario (**Active Directory**).
    - **Virtualización:** Alojamiento de máquinas virtuales (SQL Server, HCE, PACS, ERP) en un servidor físico (**VMware vSphere**).

- **Copia de Seguridad (Backup):** Servicio diario replicado en la nube para garantizar la **disponibilidad** y **continuidad del servicio** (**Veeam Backup** contra **Azure**).
- **Sistema de Gestión de Tickets (Help Desk):** Para la gestión de incidencias de soporte (**GPLI**).
- **Monitorización de Seguridad (SIEM):** Detección de intentos de acceso sospechosos y generación de alertas para el proveedor externo (**Splunk Enterprise Security**).
- **Seguridad Perimetral y Conectividad:** Uso de VPN site-to-site, firewall, IDS/IPS y antivirus (**Fortinet FortiGate 60F**, **Snort**, **Trend Micro Apex One**).
- **Autenticación Multifactor (MFA):** Para acceso a servicios cloud (**Duo Security**).

1.5 Requerimientos de acceso interno y externo

Los requerimientos de acceso son políticas y reglas que una organización aplica para permitir o denegar los accesos a determinados servicios. Entre los requerimientos de acceso interno se incluyen los siguientes:

- **Acceso a la red corporativa (LAN)**: se integra el uso de VLANs separadas, distinguiendo entre personal administrativo, personal médico e invitados.
- **Control de acceso mediante Directorio Activo:** el departamento de TI se encarga de la gestión de los usuarios, en este caso personal médico.
- **Acceso a aplicaciones clínicas y administrativas:** según el su departamento asociado, los usuarios utilizan aplicaciones como Genesis Cloud CX, Facturae o OpenEMR.
- **Acceso a herramientas de seguridad interna:** entre estas herramientas se encuentran Trend Micro Apex One (antivirus corporativo) y Snort (sistema IDS/IPS).

Por otro lado, entre los requerimientos de acceso externo se encuentran:

- **Acceso a servicios de la nube:** entre los que se incluyen Microsoft Azure, AWS (WordPress + WooCommerce), Google Workspace y Salesforce Health Cloud.
- **Acceso de proveedores externos:** dichos proveedores realizan servicios de mantenimiento, de limpieza y certificaciones de equipos médicos.
- **Acceso a la web o portal externo:** esto permite el acceso público por parte de los pacientes y/o familiares.
- **Acceso remoto entre la sede central y las clínicas:** esto se lleva a cabo mediante VPN site-to-site IPSec.

1.6 Política de seguridad

Las políticas definidas por Medisalud Integral S.A. y que debemos conseguir llevar a cabo son las siguientes:

- **Confidencialidad**: proteger los datos de los pacientes y empleados frente al acceso no autorizado.
- **Integridad**: la información clínica y administrativa no debe ser alterada de forma indebida.
- **Disponibilidad**: garantizar que los sistemas críticos como HCE, PACS o ERP estén disponibles en cada momento.
- **Cumplimiento normativo**: Mantenerse en los estándares definidos por el RGDP, LOPDGDD e ISO 27001.
- **Gestión de proveedores**: se debe exigir a las empresas externas (gestoría, mantenimiento, servicios en la nube, ...) cláusulas contractuales que incluyan compromisos de confidencialidad y seguridad.
- **Concienciación del personal**: formación periódica del personal en prácticas de seguridad, incluyendo prevención de phishing y el uso de contraseñas seguras.

1.7 Agentes implicados

Los agentes que interactuarán con Medisalud Integral S.A. incluyen los siguientes:

- **Personal médico**: Médicos, enfermeros y especialistas que acceden al historial clínico de los pacientes, PACS y sistemas de diagnósticos para la atención de los pacientes.
- **Personal administrativo**: Empleados encargados en citas, facturación, nóminas, y gestión documental mediante herramientas como A3 ERP o FacturaE.
- **Pacientes y familiares**: Usuarios que reciben servicios asistenciales cuyo tratamiento requiere gestionar información clínica sensible.
- **Proveedores tecnológicos**: Empresas responsables del alojamiento en la nube (Azure, AWS), gestión de correo electrónico y colaboración (Google Workspace), así como servicios de seguridad gestionada y soporte técnico.
- **Proveedores de infraestructura y mantenimiento**: Entidades encargadas del mantenimiento de las instalaciones, equipos médicos, y soporte físico de TI.
- **Auditores y consultores externos**: Encargados de verificar el cumplimiento normativo, la ciberseguridad y la calidad de los productos internos.

2. Análisis de riesgos

2.1 Catálogo de activos

El catálogo de activos es un conjunto de información, servicios y recursos que una organización considera valiosos. Su protección es crítica para el óptimo funcionamiento de la empresa.

A continuación, se detalla el inventario de activos clasificados por categorías.

- **Servicios**
  - **Atención médica presencial:** consultas, seguimiento de patologías crónicas, tratamientos ambulatorios.
  - **Servicios de telemedicina:** tele consulta, comunicación médico-paciente.
  - **Diagnóstico clínico:** pruebas básicas, radiología mediante PACS.
  - **Gestión de citas:** presencial, telefónica y online.
  - **Servicios administrativos y de facturación.**
- **Datos e información**
  - **Historias clínicas electrónicas (HCE):** datos médicos altamente sensibles.
  - **Imágenes diagnósticas:** radiología almacenada en sistemas PACS.
  - **Resultados de laboratorio:** integrados con HCE.
  - **Datos personales de pacientes:** identidad, contacto, seguros, consentimientos.
  - **Datos de empleados:** nóminas, contratos, credenciales.
  - **Información financiera:** facturación, contabilidad, informes económicos.
  - **Documentación corporativa interna:** protocolos médicos, procedimientos, manuales, informes.
- **Aplicaciones de software**
  - **OpenEMR:** gestión de historias clínicas.
  - **OsiriX MD (PACS):** gestión de imágenes diagnósticas.
  - **LabWare LIMS:** resultados de laboratorio.
  - **Salesforce Health Cloud:** CRM para atención al paciente.
  - **Genesys Cloud CX:** call center y VoIP.
  - **SAP Business One:** ERP sanitario.
  - **A3 ERP:** nóminas y contabilidad.
  - **WordPress + WooCommerce:** portal web / teleconsulta.
  - **Active Directory:** gestión de identidades y autenticación.
  - **Veeam Backup:** backup crítico.
  - **Splunk Enterprise Security:** SIEM externo.

    - **Herramientas auxiliares:** Office, Google Workspace, clientes VPN, etc.
- **Hardware**
    - **30 PC/portátiles de empleados** (Windows 11).
    - **Servidores Dell PowerEdge**, virtualizados con VMware vSphere.
    - **Equipos médicos conectados:** radiología, ECG, etc.
    - **Teléfonos IP y dispositivos VoIP.**
- **Personal**
    - Dirección general y médica.
    - Médicos y enfermería.
    - Administración y finanzas.
    - Atención al paciente (recepción + call center).
    - TI interno y proveedores de seguridad.
    - Empresas externas: mantenimiento, limpieza, certificación médica.
- **Redes de comunicaciones**
    - **LAN interna segmentada:** VLAN Médica, Administrativa e Invitados.
    - **Redes entre sedes:** VPN site-to-site IPSec.
    - **Firewalls Fortinet FortiGate 60F.**
    - **Routers Cisco RV340.**
    - **Switches HP Aruba 2530.**
    - **WiFi corporativa y WiFi de invitados (aislada).**
- **Soportes de información**
    - **Backups locales y en Azure** (copias HCE, bases de datos y servidores).
    - **Servidores físicos y máquinas virtuales** alojando servicios críticos.
    - **Documentos en repositorios cloud (Google Workspace).**
- **Equipos auxiliares**
    - Impresoras, escáneres, proyectores.
    - Dispositivos de videoconferencia.
- **Instalaciones**
    - **Clínicas físicas:** despachos médicos, consultas, salas de diagnóstico.
    - **Sala de servidores:** control de acceso, climatización, SAI/UPS.
    - **Recepción y call center.**
- **Imagen y reputación**
    - Marca corporativa.
    - Relación con pacientes y familiares.
    - Presencia en redes sociales y portal web.

Inventario de activos:

Clase	Descripción
[D] Datos e información	Información clínica, administrativa o personal tratada por la empresa.
[S] Servicios	Prestación sanitaria y soporte administrativo asociado.
[SW] Aplicaciones Software	Aplicaciones clínicas, administrativas y de gestión.
[HW] Hardware	Equipos médicos, servidores, estaciones de trabajo y dispositivos de red.
[P] Personal	Usuarios internos y externos que interactúan con los activos.
[N] Redes de comunicación	Infraestructura de conectividad local y remota.
[SI] Soporte de Información	Medios de almacenamiento y backup.
[EA] Equipamiento Auxiliar	Impresoras, teléfonos IP y dispositivos de videoconferencia.
[I] Instalaciones	Consultas, salas de tratamiento, sala de servidores.
[IR] Imagen y Reputación	Consultas, salas de tratamiento, sala de servidores.

Valor	Descripción
Muy Alto	Impacto crítico: paralización del servicio clínico, daños legales o reputacionales graves.
Alto	Impacto severo en los procesos asistenciales o administrativos.
Medio	Afectación parcial o recuperable del servicio.
Bajo	Consecuencias limitadas y fácilmente recuperables.

Código	Nombre	Descripción	Dependencia y justificaciones
D.1	Historias Clínicas Electrónicas (HCE)	Información médica completa de los pacientes (datos personales, diagnósticos, tratamientos).	SW.1 gestiona; HW.2 almacena; SI.1 copias.
Conf.: Muy Alta, Integ.: Muy Alta, Disp.: Alta, Trazab.: Alta			
D.2	Imágenes Diagnósticas (PACS)	Radiografías, TAC, ecografías y estudios DICOM.	SW.2 (OsiriX) gestiona; HW.2 PACS; SI.1 copias.
Conf.: Alta, Integ.: Alta, Disp.: Alta, Trazab.: Alta			

D.3	Datos administrativos y de facturación	Facturas, seguros, proveedores, pagos.	SW.3 (SAP), SW.4 (A3 ERP), SI.1 backups.
Conf.: Alta, Integ.: Alta, Disp.: Media, Trazab.: Media			
D.4	Datos personales	Información personal de pacientes y empleados.	SW.1, SW.3, Active Directory.
Conf.: Muy Alta, Integ.: Alta, Disp.: Media, Trazab.: Alta			
S.1	Atención Clínica	Evaluación, diagnóstico y tratamiento de pacientes.	D.1 HCE; D.2 PACS; HW.1 equipos; N.1 red interna.
Conf.: Muy Alta, Integ.: Alta, Disp.: Muy Alta, Trazab.: Alta			
S.2	Telemedicina	Teleconsultas online mediante plataforma web.	SW.6 portal web; N.1; SI.1 continuidad.
Conf.: Alta, Integ.: Alta, Disp.: Alta, Trazab.: Media			
S.3	Gestión de citas y recepción	Registro, asignación y modificación de citas.	SW.5 CRM; HW.1 recepción.
Conf.: Media, Integ.: Media, Disp.: Alta, Trazab.: Media			
SW.1	OpenEMR	Software de historial clínico electrónico.	HW.2; N.1; SI.1 backups.
Conf.: Muy Alta, Integ.: Muy Alta, Disp.: Alta, Trazab.: Alta			
SW.2	OsiriX MD (PACS)	Gestión de imágenes médicas.	HW.2 PACS; N.1.
Conf.: Alta, Integ.: Alta, Disp.: Alta, Trazab.: Alta			
SW.3	SAP Business One	ERP de finanzas y administración.	D.3; N.1; SI.1.
Conf.: Alta, Integ.: Alta, Disp.: Media, Trazab.: Media			
SW.4	A3 ERP (RRHH)	Gestión de personal y nóminas.	D.4; HW.2; N.1.
Conf.: Muy Alta, Integ.: Alta, Disp.: Media, Trazab.: Alta			
SW.5	Salesforce Health Cloud	CRM clínico para citas y pacientes.	HW.1; N.1; SI.1.
Conf.: Alta, Integ.: Media, Disp.: Alta, Trazab.: Media			
SW.6	WordPress / Teleconsulta	Web corporativa y plataforma de telemedicina.	Hosting externo; N.1; SI.1.
Conf.: Media, Integ.: Media, Disp.: Alta, Trazab.: Media			
HW.1	Equipos de usuario	Pcs y portátiles clínicos y administrativos.	SW clínicos; N.1.
Conf.: Media, Integ.: Media, Disp.: Media, Trazab.: Baja			
HW.2	Servidores Dell + VMware	Infraestructura donde residen EMR, PACS y ERP.	N.1; SI.1; sistemas críticos.
Conf.: Alta, Integ.: Alta, Disp.: Muy Alta, Trazab.: Media			
N.1	Red interna y VPN	VLAN clínica, administrativa y enlace seguro con sedes.	Dependen todos los SW clínicos.
Conf.: Muy Alta, Integ.: Alta, Disp.: Muy Alta, Trazab.: Alta			

SI.1	Backups (Veeam + Azure)	Copias de seguridad de todos los datos y servidores.	HW.2 y D.1–D.4.
Conf.: Muy Alta, Integ.: Muy Alta, Disp.: Alta, Trazab.: Muy Alta			
EA.1	Equipos auxiliares	Impresoras, escáneres y VoIP.	N.1; soporte documental.
Conf.: Baja, Integ.: Media, Disp.: Media, Trazab.: Baja			
I.1	Instalaciones físicas	Consultas, salas de servidores, recepción.	Necesarias para la actividad asistencial.
Conf.: Media, Integ.: Media, Disp.: Alta, Trazab.: Baja			
IR.1	Reputación institucional	Confianza del paciente e imagen pública.	Asociada a D.1, S.1, S.2 y protección de datos.
Conf.: Muy Alta, Integ.: Alta, Disp.: Media, Trazab.: Alta			

2.2 Listado de amenazas

A continuación, se muestra un catálogo con todas las amenazas posibles sobre los activos identificados en el apartado anterior:

- **Amenazas producidas por desastres naturales [ND]**:
  - *Incendios [ND.1]*: Daños en los activos producidos por el fuego que afectan a la disponibilidad de los recursos del sistema. Los tipos de activos afectados son los **Hardware**, los **Soporte de información**, el **Equipamiento auxiliar** y las propias **Instalaciones**.
  - *Inundaciones [ND.2]*: Daños en los activos producidos por filtraciones de agua que afectan a la disponibilidad de los recursos del sistema. Los tipos de activos afectados son los **Hardware**, los **Soporte de información**, el **Equipamiento auxiliar** y las propias **Instalaciones**.
  - *Otros desastres naturales [ND.3]*: Una serie de acontecimientos específicos del entorno como la contaminación del aire o del agua, fenómenos como pueden ser climático o meteorológico. Los tipos de activos afectados son los **Hardware**, los **Soporte de información**, el **Equipamiento auxiliar** y las propias **Instalaciones**.
- **Amenazas relacionadas con la infraestructura [IS]**:
  - *Averías de origen físico o lógico [IS.1]*: Fallos en el hardware por desgaste o en el software por la aparición de errores. Los tipos de activos afectados son las **Aplicaciones de software**, los **Hardware**, los **Soporte de Información** y el **Equipamiento Auxiliar**.

- *Cortes del suministro eléctrico [IS.2]*: El cese de la alimentación de la potencia eléctrica puede deberse accidentes o actos deliberados. Los tipos de activos afectados son los **Hardware**, los **Soporte de Información** y el **Equipamiento Auxiliar**.
- *Fallo de servicio de comunicaciones [IS.3]*: Dejar de transmitir información de un punto a otro, con posible consecuencia de la destrucción de medios físicos o la detención de los centros de conmutación de forma accidental o intencionada. Evidentemente, los activos que se ven afectados son las propias **Redes de comunicaciones**.
- *Interrupción de otros servicios [IS.4]*: Posible dependencia de equipos a otros recursos o servicios del sistema que puede tener problemas de funcionamiento. El activo afectado en este caso es el **Equipamiento Auxiliar**.

- **Amenazas por errores y fallos no intencionados [EN]**
  - *Errores de los usuarios [EN.1]*: Equivocación al usar un servicio que puede derivar en la destrucción de la información. Los tipos de activos afectados son los **Datos e información**, los **Servicios**, las **Aplicaciones de software,** los **Soporte de información** y la **Imagen y reputación**.
  - *Errores de la administración [EN.2]*: Equivocaciones de las personas responsables que pueden derivar en una mala configuración y monitorización de los sistemas. Los tipos de activos afectados son los **Datos e información**, los **Servicios**, las **Aplicaciones de software**, los **Hardware**, las **Redes de comunicaciones**, los **Soporte de información** y la **Imagen y reputación**.
  - *Difusión de software dañino [EN.3]*: Propagación accidental por los equipos de malwares que afectan a las **Aplicaciones de software**.
  - *Escapes de información [EN.4]*: Las filtraciones de datos que llegan al conocimiento de personas que no deberían tener conocimiento de ellos ponen en riesgo la confidencialidad. Afecta al tipo de activo de **Imagen y reputación**.
  - *Indisponibilidad del personal [EN.5]*: Ausencia por causas mayores al puesto de trabaja del **Personal**.
- **Amenazas intencionadas [A]**
  - *Suplantación de identidad [A.1]*: Atacantes que consiguen acceso un usuario autorizado para hacerse pasar por él. Los tipos de activos afectados son los **Datos e información**, los **Servicios**, las **Aplicaciones de software** y las **Redes de comunicaciones**.

- *Abuso de privilegios de acceso [A.2]*: Aprovechamiento de un usuario para un determinado propósito que no es de su competencia. Los tipos de activos afectados son los **Datos e información**, los **Servicios**, las **Aplicaciones de software**, los **Hardware**, las **Redes de comunicaciones** y los **Soporte de información**.
- *Difusión de software dañino [A.3]*: Propagación intencionada por los equipos de malwares que afectan a las **Aplicaciones de software**.
- *Alteración de secuencia [A.4]*: Alterar el orden de los mensajes transmitidos para afectar a su significado. Afecta a los **Servicios**, las **Aplicaciones de software** y las **Redes de comunicaciones**.
- *Análisis del tráfico [A.5]*: El usuario malicioso mapea la red para analizar el contenido y planificar el ataque de forma precisa. Afecta a las **Redes de comunicaciones.**
- *Denegación de servicio [A.6]*: Ataques que aumentan la carga de trabajo del sistema de forma desmesura, provocando su caída y la inutilización los recursos del sistema. Los tipos de activos afectados son los **Servicios**, los **Hardware** y las **Redes de comunicaciones**.
- *Robo de información [A.7]*: La sustracción de información de forma tanto física como de forma remota pueden provocar la indisponibilidad de un servicio. Los tipos de activos afectados son los **Hardware**, los **Soporte de información** y el **Equipamiento Auxiliar**.
- *Ocupación enemiga [A.8]*: Cuando los centros han sido invadidos y carecen de control sobre sus medios. Afecta a las **Instalaciones**.

2.3 Listado de riesgos

Una vez identificadas todas las amenazas que pueden afectar los activos de la empresa, determinamos el nivel de riesgo de cada amenaza (impacto) a partir del producto entre el nivel de degradación sobre el valor de un activo y la probabilidad de que se materialice.

Los niveles de degradación posibles son:

- Muy bajo (Nivel 1)
- Bajo (Nivel 2)
- Medio (Nivel 3)
- Alto (Nivel 4)
- Muy alto (Nivel 5)

La probabilidad de que surja cierta amenaza es:

- Muy baja (0.01%)
- Baja (0.1%)
- Media (1%)
- Alta (10%)
- Muy alta (100%)

La forma de calcular el impacto se realizará dotando a cada escalón de nivel de degradación de un **valor, muy bajo = 1, bajo = 2… hasta muy alto = 5**. Y multiplicándolo por el nivel de probabilidad que se regirá de la misma manera. Un ejemplo de esto sería la amenaza **N.1** con el activo **"Hardware"**, cuyo nivel de degradación sería Muy alto y cuya probabilidad sería baja. Esto llevado a las matemáticas nos resultaría en un **5 x 2 = 10**, que se catalogaría como **bajo**.
Este sería el espectro:

- 1–5 = Muy bajo
- 6–10 = Bajo
- 11–15 = Medio
- 16–20 = Alto
- 21–25 = Muy alto

Código De Amenaza	Tipo de Activo	Nivel Degradación	Probabilidad	Impacto
ND.1	*HW*	Muy alto	Baja	**Bajo**
ND.1	*SI*	Muy alto	Baja	**Bajo**
ND.1	*EA*	Muy alto	Baja	**Bajo**
ND.1	*I*	Muy alto	Baja	**Bajo**
ND.2	*HW*	Alto	Muy baja	**Muy bajo**
ND.2	*SI*	Alto	Muy baja	**Muy bajo**
ND.2	*EA*	Alto	Muy baja	**Muy bajo**
ND.2	*I*	Alto	Muy baja	**Muy bajo**
ND.3	*HW*	Muy alto	Baja	**Bajo**
ND.3	*SI*	Muy alto	Baja	**Bajo**
ND.3	*EA*	Muy alto	Baja	**Bajo**
ND.3	*I*	Muy alto	Baja	**Bajo**
IS.1	*SW*	Alto	Media	**Medio**
IS.1	*HW*	Muy alto	Media	**Alto**
IS.1	*SI*	Muy alto	Media	**Alto**
IS.1	*EA*	Muy alto	Media	**Alto**
IS.2	*HW*	Muy alto	Media	**Alto**
IS.2	*SI*	Muy alto	Media	**Alto**
IS.2	*EA*	Alto	Media	**Medio**

IS.3	*N*	Alto	Alta	**Alto**
IS.4	*EA*	Bajo	Media	**Bajo**
EN.1	*D*	Alto	Alta	**Alto**
EN.1	*S*	Alto	Alta	**Alto**
EN.1	*SW*	Alto	Alta	**Alto**
EN.1	*SI*	Alto	Alta	**Alto**
EN.1	*IR*	Medio	Alta	**Medio**
EN.2	*D*	Muy alto	Media	**Alto**
EN.2	*S*	Muy alto	Media	**Alto**
EN.2	*SW*	Muy alto	Media	**Alto**
EN.2	*HW*	Muy alto	Media	**Alto**
EN.2	*N*	Muy alto	Media	**Alto**
EN.2	*SI*	Muy alto	Media	**Alto**
EN.2	*IR*	Alto	Media	**Medio**
EN.3	*SW*	Muy alto	Media	**Medio**
EN.4	*IR*	Alto	Alto	**Alto**
EN.5	*P*	Bajo	Alta	**Bajo**
A.1	*D*	Alto	Alta	**Alto**
A.1	*S*	Alto	Alta	**Alto**
A.1	*SW*	Alto	Alta	**Alto**
A.1	*N*	Alto	Alta	**Alto**
A.2	*D*	Muy alto	Muy alta	**Muy alto**
A.2	*S*	Muy alto	Muy alta	**Muy alto**
A.2	*SW*	Muy alto	Muy alta	**Muy alto**
A.2	*HW*	Muy alto	Muy alta	**Muy alto**
A.2	*N*	Muy alto	Muy alta	**Muy alto**
A.2	*SI*	Muy alto	Muy alta	**Muy alto**
A.3	*SW*	Muy alto	Muy alta	**Muy alto**
A.4	*S*	Alto	Alta	**Alto**
A.4	*SW*	Alto	Alta	**Alto**
A.4	*N*	Alto	Alta	**Alto**
A.5	*N*	Medio	Alta	**Alto**
A.6	*S*	Muy alto	Alta	**Alto**
A.6	*HW*	Muy alto	Alta	**Alto**
A.6	*N*	Muy alto	Alta	**Alto**
A.7	*HW*	Alto	Alta	**Alto**
A.7	*SI*	Alto	Alta	**Alto**
A.7	*EA*	Alto	Alta	**Alto**
A.8	*I*	Alto	Muy baja	**Muy bajo**

2.4 Priorización de riesgos

La priorización de riesgos se analizará considerando la probabilidad de que se dé un evento o amenaza junto con el impacto que tendría para la organización. Para ello utilizaremos una matriz de riesgo que clasificará los riesgos por niveles de prioridad.

Al igual que anteriormente se calculará como el producto entre la probabilidad de que dicha amenaza ocurra y el impacto que provocaría en la empresa.

Es decir, **muy bajo = 1, bajo = 2… hasta muy alto = 5**. El valor de impacto seleccionado será el valor de impacto más repetido para cada amenaza.

CÓDIGO	IMPACTO	PROBABILIDAD	RIESGO
A.2	5	5	**25**
A.3	5	5	**25**
A.6	4	4	**16**
IS.3	4	4	**16**
A.1	4	4	**16**
A.7	4	4	**16**
EN.1	4	4	**16**
A.5	4	4	**16**
A.4	4	4	**16**
IS.1	4	3	**12**
IS.2	4	3	**12**
EN.2	4	3	**12**
EN.3	3	3	**9**
EN.5	2	4	**8**
EN.4	2	3	**6**
IS.4	2	3	**6**
ND.1	2	2	**4**
ND.3	2	2	**4**

ND.2	1	1	**1**
A.8	1	1	**1**

Podemos observar entonces que los riesgos con mayor prioridad serían las amenazas intencionadas como el **Abuso de privilegios de acceso** o la **Difusión de software dañino**, también otros como los **Ataques de Denegación de servicio, Fallo del servicio de comunicaciones o** ataques de **Suplantación de identidad.**

3. Salvaguardas (Contramedidas de seguridad)

3.1 Por objetivo de seguridad

En este apartado clasificamos las salvaguardas según la dimensión de seguridad que desempeñan, siguiendo las políticas de seguridad planteadas:

- **Garantizar la confidencialidad**: es crucial evitar que los datos de la organización sean expuestos al público, robados o mal utilizados. Por ello, se plantean las siguientes salvaguardas:
    - [PR.1]: Autenticación fuerte para teleconsulta (MFA, VPN).
    - [PR.2], [AD.1]: Control de acceso según el rol en todos los sistemas.
    - [PR.3], [IM.1]: Encriptación de clave pública (AES-256).
    - [PR.4], [DR.1]: HTTPS obligatorio y certificados válidos.
    - [MN.1], [DC.1]: Protocolos de detección de datos de los pacientes.
    - [PR.5], [DR.2]: Política de contraseñas robusta.
    - [PR.6], [DR.3]: MFA para administradores de sistemas.
    - [PR.7], [DC.2]: Antivirus y firewall habilitado en todos los equipos.
    - [PR.8], [IM.2]: Encriptación de discos (por ejemplo, con BitLocker).
    - [PR.9], [RC.1]: Actualizaciones automáticas del sistema operativo.
    - [PR.10], [RC.2]: Firmware actualizado.
    - [PR.11]: Uso seguro de virtualización (VMware hardening).
    - [PR.12]: Configuración segura de SIP (Session Initiation Protocol).
    - [PR.13]: Uso de VPN segura entre redes.
    - [PR.14]: Actualización del firmware de routers y switches.
    - [PR.15], [IM.3]: Aislar Wifi de invitados de la Wifi corporativa.
    - [PR.16]: Proteger la Wifi corporativa mediante WPA3.
    - [PR.17], [IM.4]: Control de acceso a los repositorios en la nube.
    - [PR.18]: Acceso restringido/controlado a impresoras y escáneres.
    - [PR.19], [IM.5]: Eliminación segura de documentos y memoria.
    - [PR.20], [IM.6]: Control de acceso físico.

- **Garantizar la integridad**: es fundamental que los datos de la organización sean exactos, completos y confiables en todo su ciclo de vida. Por ello, se proponen las siguientes salvaguardas:
    - [IM.7]: Cifrado de datos financieros y personales.
    - [RC.3], [IM.8]: Copias de seguridad periódicas.
    - [PR.21], [DR.4]: Firewall para servidores PACS.
    - [MN.2], [DC.3]: Monitoreo de cambios en documentos críticos.
    - [DC.4], [CR.1]: Controles de integridad de datos.
    - [PR.22], [CR.2]: Parches y actualizaciones periódicas de todas las herramientas usadas (OpenEMR, OsiriX MD, Splunk Enterprise Security, etc).
    - [PR.23], [IM.9]: Implementación de políticas de seguridad física.
- **Garantizar la disponibilidad**: es crítico que los datos de la organización sean accesibles y operativos cuando se necesitan. Por ello, se plantean las siguientes salvaguardas:
    - [MN.3], [DC.5]: Monitoreo continuo de la disponibilidad y rendimiento de los sistemas.
    - [PR.24], [IM.10]: Segmentación de red (VLAN).
    - [PR.25], [DC.6]: Monitoreo del hardware.
    - [RC.4], [IM.11]: Pruebas periódicas de restauración.
    - [RC.5], [IM.12]: Backups locales y en la nube.
    - [PR.26], [IM.13]: Utilización de sistemas de alimentación ininterrumpida (SAI).
    - [PR.27], [IM.14]: Sistemas de detección de incendios.
- **Mantener el cumplimiento de la normativa**: es totalmente necesario cumplir la normativa porque de esa manera se asegura que la organización opere legal, segura y sostenible. Por ello, se plantean las siguientes salvaguardas:
    - [AW.1]: Capacitación en el ámbito de la ciberseguridad y protección de los datos.
    - [PR.28]: Gestión del privilegio según rol y/o necesidad.
    - [AD.2]: Políticas de uso aceptable de TI.
    - [RC.6]: Plan de continuidad adecuado ante la ausencia de personal crítico.
    - [IM.15], [AD.3]: Políticas de comunicación y manejo de crisis.
    - [IM.16], [AD.4]: Gestión de redes sociales.
    - [PR.29], [AD.5]: Implementación de un sistema CRM.

3.2 Por tipo de activo

Teniendo la descripción anterior del catálogo de activos y sus amenazas identificadas, se plantean las siguientes salvaguardas adaptadas a cada tipo de activo, listando todos los elementos de la tabla a partir de los códigos de sus clases:

CLASE DE ACTIVO	CLASES DE AMENAZAS	CLASES DE SALVAGUARDAS
[D]	[EN.1]; [EN.2]; [A.1]; [A.2]	[PR.3]; [IM.1]; [RC.3]; [IM.8]; [PR.21]; [DR.4]; [PR.24]; [IM.10]; [MN.2]; [DC.3]; [DC.4]; [CR.1]
[S]	[EN.1]; [EN.2]; [A.1]; [A.2]; [A.4]; [A.6]	[PR.1]; [PR.2]; [AD.1]; [MN.3]; [DC.5]; [IM.7]
[SW]	[IS.1]; [EN.1]; [EN.2]; [EN.3]; [A.1]; [A.2]; [A.3]; [A.4]	[PR.22]; [CR.2]; [PR.4]; [DR.1]; [MN.1]; [DC.1]; [PR.5]; [DR.2]; [PR.6]; [DR.3]
[HW]	[ND.1]; [ND.2]; [ND.3]; [IS.1]; [IS.2]; [EN.2]; [A.2]; [A.6]; [A.7]	[PR.7]; [DC.2]; [PR.8]; [IM.2]; [PR.9]; [RC.1]; [PR.25]; [DC.6]; [PR.10]; [RC.2]; [PR.11]; [PR.12]
[P]	[EN.5]	[AW.1]; [PR.28]; [AD.2]; [RC.6]
[N]	[IS.3]; [EN.2]; [A.1]; [A.2]; [A.4]; [A.5]; [A.6]	[PR.13]; [PR.14]; [PR.15]; [IM.3]; [PR.16]
[SI]	[ND.1]; [ND.2]; [ND.3]; [IS.1]; [IS.2]; [EN.1]; [EN.2]; [A.2]; [A.7]	[RC.4]; [IM.11]; [RC.5]; [IM.12]; [PR.17]; [IM.4]
[EA]	[ND.1]; [ND.2]; [ND.3]; [IS.1]; [IS.2]; [IS.4]; [A.7]	[PR.18]; [PR.19]; [IM.5]
[I]	[ND.1]; [ND.2]; [ND.3]; [A.8]	[PR.26]; [IM.13]; [PR.27]; [IM.14]; [PR.20]; [IM.6]; [PR.23]; [IM.9]
[IR]	[EN.1]; [EN.2]; [EN.4]	[IM.15]; [AD.3]; [IM.16]; [AD.4]; [PR.29]; [AD.5]

4. Controles del SGSI

4.1 Controles organizacionales

- Realización de **auditorías internas periódicas** para verificar el cumplimiento de la política de seguridad de la información y de los procedimientos definidos por la dirección.

- Contratación de **auditorías externas puntuales**, especialmente orientadas al cumplimiento del RGPD y la LOPDGDD, dada la naturaleza sensible de los datos sanitarios tratados.
- **Formación y concienciación del personal** (médicos, administración y atención al paciente) en buenas prácticas de seguridad: gestión de contraseñas, detección de correos de phishing y uso adecuado de los sistemas clínicos.
- Definición clara de **roles y responsabilidades** en materia de seguridad, con especial atención al personal del departamento de TI y a los proveedores externos.
- Establecimiento de **procedimientos de gestión de incidentes**, de forma que los empleados sepan cómo actuar y a quién notificar ante posibles brechas de seguridad.

4.2 Controles técnicos

- Uso de **técnicas de pentesting y escaneos de vulnerabilidades** sobre aplicaciones críticas como OpenEMR, WordPress (portal de citas) y servicios expuestos a Internet.
- Revisión periódica de **permisos de acceso** a los sistemas (OpenEMR, PACS, ERP, CRM) para asegurar que cada usuario solo accede a la información necesaria para su función.
- Comprobación de **los registros de eventos y logs** mediante el SIEM (Splunk Enterprise Security), simulando accesos indebidos o comportamientos anómalos.
- Verificación regular de los **planes de copia de seguridad y restauración**, asegurando que las copias realizadas con Veeam y replicadas en Azure pueden recuperarse correctamente.
- Uso de **MFA (autenticación multifactor)** en accesos críticos y servicios en la nube para reducir el riesgo de compromiso de credenciales.

4.3 Controles físicos

- Revisión y mantenimiento periódico de los **sistemas de protección física** de las instalaciones: control de acceso a salas de servidores, sistemas antiincendios y protección frente a fallos eléctricos.
- Comprobación del correcto funcionamiento de los **sistemas de soporte** (UPS, climatización de salas técnicas) para garantizar la disponibilidad de los servicios.
- Control de acceso físico a las instalaciones por parte de **proveedores externos**, asegurando que su intervención queda registrada y supervisada.

4.4 Controles de comunicación

- Configuración y revisión periódica de los **firewalls Fortinet**, asegurando que solo se permite el tráfico estrictamente necesario entre redes y sedes.
- Comprobación del correcto funcionamiento de las **VPN site-to-site** entre la sede central y las clínicas, verificando el uso de protocolos seguros (IPSec).
- Pruebas de envío de **correos electrónicos fraudulentos** simulados para evaluar la efectividad de los mecanismos antispam y la concienciación del personal.
- Segmentación de la red en **VLANs (Administrativa, Médica e Invitados)** para limitar la propagación de incidentes de seguridad.

4.5 Controles legales

- Seguimiento continuo de la **legislación vigente en materia de protección de datos**, especialmente RGPD y LOPDGDD, aplicable al sector sanitario.
- Designación y coordinación con un **Delegado de Protección de Datos (DPO)**, dada la gestión de datos de salud a gran escala.
- Revisión de los **contratos con proveedores externos** (cloud, mantenimiento, gestoría) para asegurar que incluyen cláusulas de confidencialidad y seguridad.
- Verificación periódica de que los proveedores cumplen con las **obligaciones legales** y técnicas en materia de protección de la información.

5. Bibliografía

- "Magerit", Administración Electrónica – Centro de Transferencia de Tecnología (CTT), https://administracionelectronica.gob.es/ctt/magerit/descargas. Último acceso el 13 de diciembre de 2025.
- "T3. SGSI: Gestión de la seguridad de la información", Transparencias de la asignatura GSI. Último acceso el 13 de diciembre de 2025.

6. Anexo

Todos los miembros del grupo han participado de forma igualitaria en la realización de este informe. Manifestamos estar de acuerdo con que se nos gradúe con la misma nota.